

RED TEAM

EXECUTIVE SUMMARY

Red Team Report: Pentesting de My File Server1

Evaluación de seguridad ofensiva — Resumen ejecutivo

Christian Alfredo Morales Meza | CNO IV Seguridad Informática | 01/10/2026

CONTEXTO

Contexto del Engagement

Ejercicio de pentesting de **caja negra** sobre el activo "**My File Server 1**", simulando un entorno corporativo de almacenamiento de archivos con servicios FTP, SMB/NFS y portal web informativo.

Modalidad

Sin credenciales previas | Entorno aislado, sin impacto a producción

Duración

6 horas 30 minutos

Objetivo

Identificar, explotar y documentar vulnerabilidades actuando como Red Team contratado

Metodología Aplicada

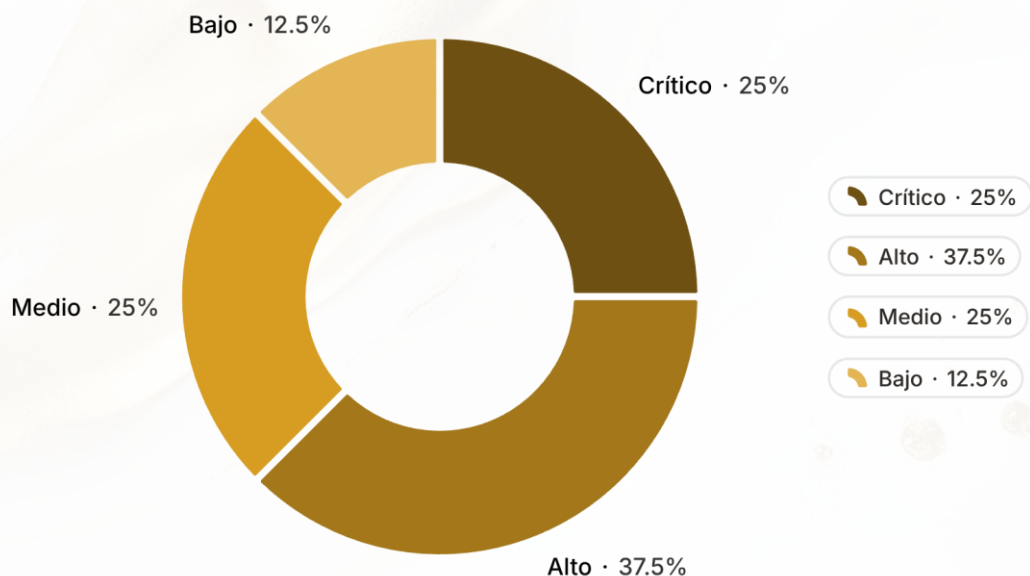
El ejercicio se basó en el estándar internacional **PTES** (Penetration Testing Execution Standard), garantizando un enfoque sistemático, reproducible y alineado con las mejores prácticas de la industria.



Cada fase se ejecutó de forma controlada, documentando evidencias y midiendo el impacto real sobre el activo.

Nivel General de Riesgo: **CRÍTICO**

Se logró el **compromiso total del sistema** (control root) sin recurrir a fuerza bruta ni herramientas avanzadas. La combinación de fallas básicas fue suficiente para tomar control completo del servidor.



2 Críticos

Explotación inmediata sin autenticación

3 Altos

Acceso no autorizado con impacto severo

2 Medios

Debilidades de configuración explotables

1 Bajo

Riesgo menor, requiere atención

Vulnerabilidades de Mayor Impacto

Acceso sin autenticación a servicios de archivos

FTP y SMB permitían escritura anónima, exponiendo el repositorio completo a cualquier atacante en la red.

Credenciales expuestas en texto plano

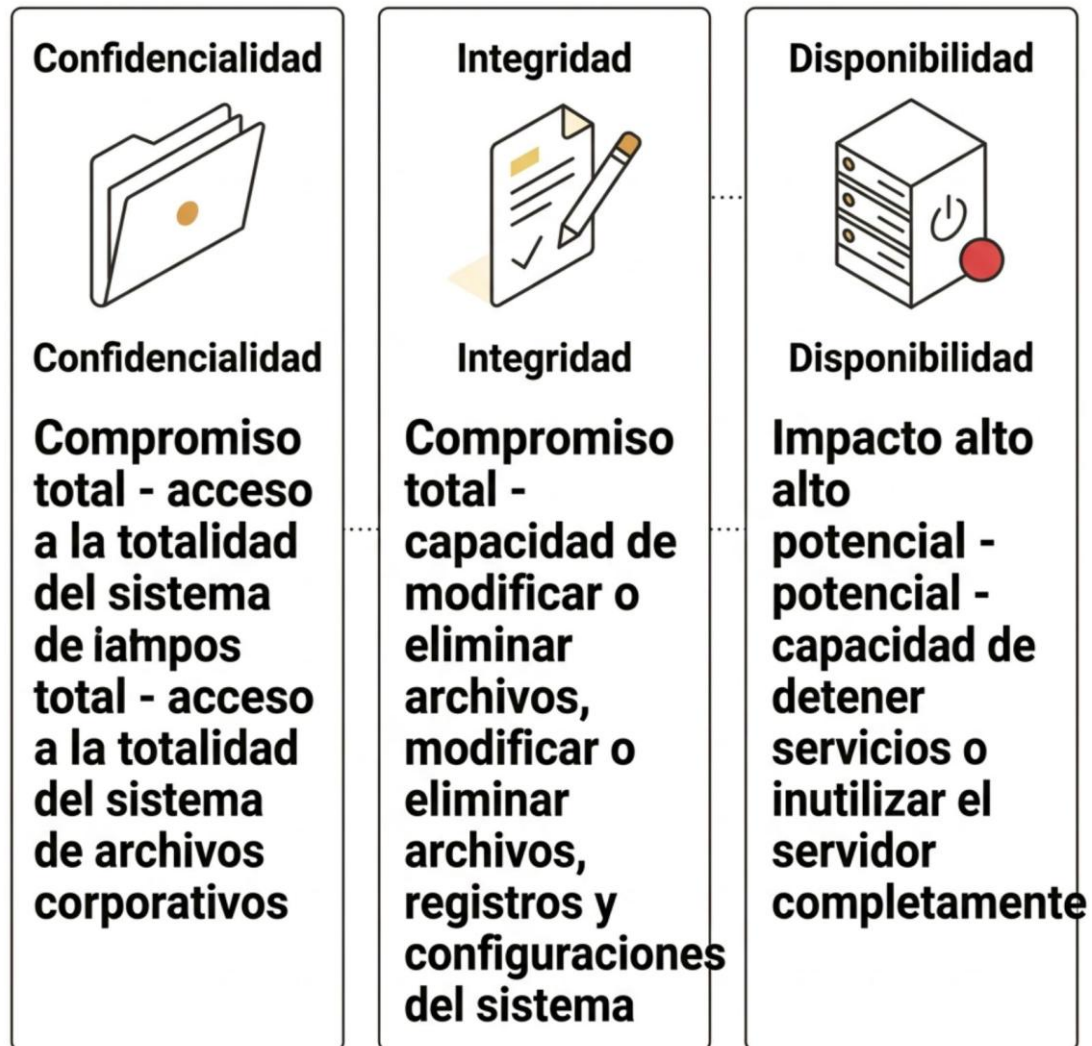
Una contraseña de usuario estaba publicada en una página pública del sitio web, accesible sin autenticación.

Sistema operativo vulnerable a DirtyCOW

El kernel desactualizado contenía una falla crítica conocida (CVE-2016-5195) que permite escalar privilegios a root.

 La combinación de estas tres fallas permitió el **control total del servidor en pocas horas**, sin herramientas avanzadas.

Escenario de Impacto — Modelo CIA



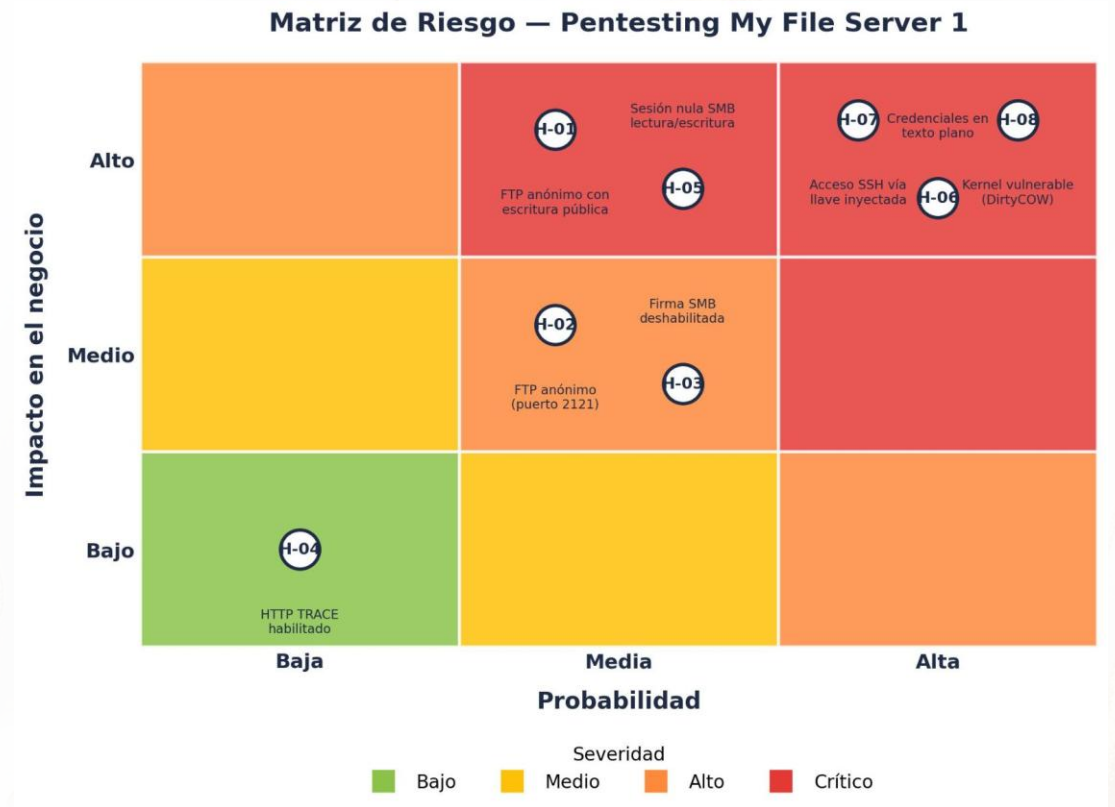
Consecuencias para el negocio

- **Interrupción operativa:** capacidad de detener servicios críticos de almacenamiento
- **Pérdida o alteración de datos:** modificación o eliminación de archivos corporativos
- **Daño reputacional:** exposición de información sensible ante clientes y reguladores
- **Riesgo regulatorio:** posible incumplimiento de normativas de protección de datos

Matriz de Riesgo: Probabilidad × Impacto

Los **8 hallazgos** se clasifican según su probabilidad de explotación y el impacto potencial sobre el negocio. Los hallazgos críticos concentran el mayor nivel de riesgo inmediato y requieren atención prioritaria.

- **Críticos (2):** Alta probabilidad / Alto impacto — explotación inmediata
- **Altos (3):** Probabilidad media-alta / Impacto alto — acceso no autorizado severo
- **Medios (2):** Probabilidad media / Impacto medio — debilidades de configuración
- **Bajo (1):** Probabilidad baja / Impacto bajo — riesgo menor



Recomendaciones Estratégicas Priorizadas

01

Eliminar credenciales en texto plano

Retirar del servidor web y adoptar gestión segura de secretos.

02

Actualizar el kernel del sistema operativo

Parchear DirtyCOW (CVE-2016-5195) y establecer gestión formal de parches.

03

Deshabilitar accesos anónimos

Eliminar FTP anónimo y sesiones nulas SMB; restringir permisos de escritura.

04

Forzar firma SMB y deshabilitar HTTP TRACE

Aplicar controles de configuración para reducir superficie de ataque.

05

Aplicar principio de menor privilegio

Revisar y restringir privilegios de cuentas de servicio al mínimo necesario.

06

Implementar monitoreo centralizado (SIEM)

Detectar actividad anómala y generar alertas automatizadas.

Roadmap de Remediación

Corto plazo — 0 a 30 días

Eliminar credenciales expuestas del servidor web.
Deshabilitar accesos anónimos en FTP y sesiones nulas en SMB. Acciones de mayor criticidad e impacto inmediato.

1

Largo plazo — 90+ días

Implementar SIEM para monitoreo centralizado.
Establecer proceso formal de patch management.
Revisión integral de privilegios de cuentas de servicio.

3

2

Mediano plazo — 30 a 90 días

Actualizar el kernel a versión parchada. Forzar firma de mensajes SMB. Deshabilitar método HTTP TRACE. Restringir escritura sobre ~/.ssh.

📌 La remediación de corto plazo reduce el riesgo crítico en más del **70%** según el modelo de severidad aplicado.

CONCLUSIÓN

Conclusión Ejecutiva

La causa raíz fue la higiene básica

Accesos por defecto y mala gestión de credenciales permitieron el compromiso total del sistema, sin necesidad de técnicas avanzadas.

La defensa básica es la primera línea

Antes de invertir en controles avanzados, es imprescindible asegurar los fundamentos: parches, credenciales y configuraciones por defecto.

Prioridad inmediata de acción

Actualizar el kernel y eliminar las credenciales expuestas son las acciones de mayor criticidad y menor costo de implementación.